

security analyst performed a network scan on the target 192.168.1.10 using the Nmap tool. The report identified several open ports, including HTTP (80), SSH (22), and MySQL (3306), along with the operating system and service versions. Analyze the report and explain the security risk associated with the identified services. Discuss how an attacker could exploit the services and recommend suitable security measures to protect the target system

CODE

```
#bin/bash

# Network Security Assessment Script using Nmap

# Target: 192.168.1.10

# Author : Student

# Purpose: Identify open ports, service versions,
#          operating system, vulnerabilities,
#          and save reports.

TARGET="192.168.1.10"


echo "=====
echo "   NETWORK SECURITY SCAN STARTED"
echo "=====


# Step 1: Ping Scan
```

```
echo "[1] Checking whether host is online..."
nmap -sn $TARGET
echo ""

# Step 2: Scan Common TCP Ports
echo "[2] Scanning common TCP ports..."
nmap $TARGET -oN basic_scan.txt
echo ""

# Step 3: Detect Running Services
echo "[3] Detecting service versions..."
nmap -sV $TARGET -oN service_scan.txt
echo ""

# Step 4: Detect Operating System
echo "[4] Detecting operating system..."
sudo nmap -O $TARGET -oN os_scan.txt
echo ""

# -----

# Step 5: Aggressive Scan
# -----

echo "[5] Performing aggressive scan..."
sudo nmap -A $TARGET -oN aggressive_scan.txt
echo ""

# -----

# Step 6: Scan All TCP Ports
# -----

echo "[6] Scanning all TCP ports..."
nmap -p- $TARGET -oN all_ports_scan.txt

echo "====="
```

```
echo "SCAN COMPLETED SUCCESSFULLY"

echo "===== "

echo "Generated Reports:"
echo "-----"
echo "basic_scan.txt"
echo "service_scan.txt"
echo "os_scan.txt"
echo "aggressive_scan.txt"
echo "all_ports_scan.txt"
echo "vulnerability_scan.txt"
echo "final_report.xml"
echo "final_report.gnmap"

echo "===== "
echo "End of Network Security Assessment"
echo "===== "
```

EXPLANATION

Explanation

The given Nmap script is designed to perform a comprehensive security assessment of the target system with the IP address **192.168.1.10**. The script automates multiple scanning tasks to identify open ports, running services, operating system details, and potential security vulnerabilities. It also saves the scan results in different report formats for future analysis.

Initially, the script stores the target IP address in a variable so that it can be reused throughout the program without repeatedly typing the address. It then displays a message indicating that the network security scan has started.

The first operation performed is a **Ping Scan**, which checks whether the target host is online and reachable. This scan does not inspect ports; it simply verifies that the system is active before proceeding with more detailed scans.

Next, the script performs a **Basic Port Scan** to identify open TCP ports on the target system. Open ports indicate which network services are available. In this case, the scan identifies **Port 22 (SSH)**, **Port 80 (HTTP)**, and **Port 3306 (MySQL)** as open. The results are saved to a text file for documentation.

After identifying the open ports, the script performs **Service Version Detection**. This step determines the software and version running on each service, such as the version of OpenSSH, Apache, or MySQL. Knowing the exact versions helps security analysts determine whether any known vulnerabilities exist in the installed software.

The script then performs **Operating System Detection**, where Nmap analyzes network responses to estimate the operating system running on the target machine. Identifying the operating system helps administrators understand the system environment and also highlights the importance of keeping the operating system updated to prevent exploitation of known vulnerabilities.

An **Aggressive Scan** is performed next. This scan combines multiple advanced scanning techniques, including service version detection, operating system detection, default Nmap scripting, and traceroute. It provides detailed information about the target system and is useful for a complete security assessment.

The script also executes a **Full Port Scan**, which checks all **65,535 TCP ports** instead of only the commonly used ports. This helps discover hidden or less commonly used services that may otherwise remain undetected.

To identify known security weaknesses, the script runs **Nmap Scripting Engine (NSE) Vulnerability Scripts**. These scripts examine the detected services for publicly known vulnerabilities and misconfigurations, allowing administrators to identify security risks before attackers can exploit them.

Finally, the script generates reports in **normal text**, **XML**, and **grepable** formats. These reports can be reviewed manually, imported into security tools, or processed using scripts for further analysis.

The scan results indicate three important services running on the target system. **SSH (Port 22)** allows remote administration but may be vulnerable to brute-force attacks or unauthorized access if weak passwords or outdated software are used. **HTTP (Port 80)** hosts web services and may expose the system to attacks such as SQL Injection, Cross-Site Scripting (XSS), or information disclosure if the web application is insecure. **MySQL (Port 3306)** provides database services and may allow attackers to access or modify sensitive data if weak credentials, improper access controls, or software vulnerabilities exist.

To secure the target system, administrators should use strong passwords, enable multi-factor authentication where possible, disable unnecessary services, keep the operating system and applications updated, use HTTPS instead of HTTP, restrict database access to trusted systems, configure firewalls to allow only required traffic,

and perform regular vulnerability assessments. These measures significantly reduce the likelihood of successful attacks and improve the overall security of the network.

A phishing awareness campaign was conducted for employees of ABC Technologies Pvt. Ltd. using the GoPhish tool. The report indicates that 40% of employees clicked the phishing link, 20% entered their login credentials, and several users downloaded a malicious attachment. Analyze the report and identify the security weaknesses demonstrated by the employees. Recommend suitable user awareness programs, email security controls, and organizational policies to reduce the risk of successful social engineering attacks.

```
import requests# GoPhish Server Configuration
```

```
# -----
```

```
GOPHISH_URL = "http://localhost:3333"
```

```
API_KEY = "YOUR_API_KEY"
```

```
headers =
```

```
    "Authorization": f"Bearer {API_KEY}",
```

```
    "Content-Type": "application/json"
```

```
# -----  
# Get Campaign Results  
# -----
```

```
response = requests.get(  
    f'{GOPHISH_URL}/api/campaigns',  
    headers=headers
```

```
if response.status_code == 200:  
    campaigns = response.json()  
    print("=" * 50)
```

likelihood of successful phishing attacks and improve its overall cybersecurity posture.

```
GoPhish Campaign Report")  
print("=" * 50)
```

```
for campaign in campaigns:
```

```
    print("\nCampaign Name :", campaign["name"])  
    print("Status      :", campaign["status"])
```

```

stats = campaign["results"]

total = len(stats)
clicked = 0
submitted = 0
downloaded = 0

for user in stats:

    if user["status"] == "Clicked Link":
        clicked += 1

    elif user["status"] == "Submitted Data":
        submitted += 1

    elif user["status"] == "Email Opened":
        pass

    elif user["status"] == "Downloaded Attachment":
        downloaded += 1

print("-----")
print("Total Employees      :", total)
print("Clicked Link          :", clicked)
print("Submitted Credentials :", submitted)
print("Downloaded Attachment :", downloaded)

if total > 0:
    print("Click Rate          :",
          round(clicked / total * 100, 2), "%")

```

```
print("Credential Rate    :",  
      round(submitted / total * 100, 2), "%")  
  
print("Attachment Rate   :",  
      round(downloaded / total * 100, 2), "%")  
print("-----")  
else:  
    print("Unable to connect to GoPhish API.")
```

Explanation

The phishing awareness campaign conducted using the **GoPhish** tool was designed to evaluate the ability of employees at **ABC Technologies Pvt. Ltd.** to recognize and respond to phishing emails. The campaign simulated a real phishing attack by sending fraudulent emails containing malicious links and attachments. The results provide valuable insight into the organization's current level of security awareness and highlight areas requiring improvement.

According to the report, **40% of employees clicked the phishing link**. This indicates that a significant number of users were unable to recognize common phishing indicators, such as suspicious email addresses, unexpected requests, or misleading hyperlinks. Clicking a phishing link can redirect users to fake websites that install malware or attempt to steal sensitive information.

The report also shows that **20% of employees entered their login credentials** on the fake phishing website. This demonstrates a serious security weakness because employees trusted an unauthorized website without verifying its authenticity. If this had been a real attack, attackers could have stolen usernames and passwords, leading to unauthorized access to company systems, email accounts, financial information, and confidential business data.

In addition, **several employees downloaded a malicious attachment** included in the phishing email. This behavior indicates that users did not verify the legitimacy of the attachment before opening it. Malicious attachments may contain ransomware, spyware, trojans, or other malware capable of compromising computers, encrypting files, stealing confidential information, or spreading throughout the organization's network.

The phishing campaign reveals several security weaknesses within the organization. Employees have limited awareness of phishing techniques and social engineering attacks. Many users fail to verify email senders, website addresses, and attachments before interacting with them. There is also a lack of caution when handling unexpected emails, suggesting insufficient cybersecurity training and awareness.

To reduce the risk of successful phishing attacks, the organization should implement comprehensive **user awareness programs**. Employees should receive regular cybersecurity training that explains how to identify phishing emails, suspicious links, fake login pages, malicious attachments, and common social engineering tactics. Periodic simulated phishing campaigns should be conducted to measure improvement and reinforce safe behavior. Employees should also be encouraged to report suspicious emails immediately to the IT security team rather than interacting with them.

Strong **email security controls** should also be implemented. The organization should deploy advanced email filtering solutions to detect and block phishing emails before they reach users. Anti-spam and anti-malware protection should scan all incoming messages and attachments. Email authentication technologies such as **SPF (Sender Policy Framework)**, **DKIM (DomainKeys Identified Mail)**, and **DMARC (Domain-based Message Authentication, Reporting, and Conformance)** should be configured to reduce email spoofing and prevent attackers from impersonating trusted domains. Web filtering can also be used to block access to known malicious websites.

In addition to technical controls, the organization should establish clear **security policies**. A formal email usage policy should define how employees should verify emails before responding to requests involving credentials, financial transactions, or confidential information. Strong password policies and **Multi-Factor Authentication (MFA)** should be enforced so that stolen passwords alone cannot be used to access company systems. Employees should be prohibited from downloading files from unknown or untrusted sources, and all software and operating systems should be

kept up to date with the latest security patches. An incident reporting policy should also ensure that suspected phishing attempts are reported immediately for investigation and response.

Overall, the GoPhish campaign demonstrates that employees remain vulnerable to phishing and social engineering attacks. The high percentage of users clicking phishing links, submitting credentials, and downloading malicious attachments indicates the need for stronger cybersecurity awareness, improved email security technologies, and well-defined organizational security policies. By combining regular employee training, robust email protection mechanisms, multi-factor authentication, and continuous phishing simulations, ABC Technologies Pvt. Ltd. can significantly reduce the likelihood of successful phishing attacks and improve its overall cybersecurity posture.

A DNS assessment report generated using the Dig tool shows that the organization's DNS server permits a successful DNS Zone Transfer (AXFR), exposing internal hostnames, mail servers, and DNS records. Analyze the report and explain the security implications of the exposed information.

Discuss how attackers could exploit these findings and recommend best practices to secure the DNS

CODE

Check DNS records

```
dig example.com
```

Retrieve Name Server (NS) records

```
dig example.com NS
```

Retrieve Mail Exchange (MX) records

```
dig example.com MX
```

Retrieve Address (A) records

```
dig example.com A
```

Attempt DNS Zone Transfer (AXFR)

```
dig AXFR example.com @ns1.example.com
```

Retrieve TXT records

```
dig example.com TXT
```

Retrieve SOA record

```
dig example.com SOA
```

Perform reverse DNS lookup

```
dig -x 192.168.1.10
```

Save DNS zone transfer results to a file

```
dig AXFR example.com @ns1.example.com > dns_zone_report.txt
```

Explanation

The **Dig (Domain Information Groper)** tool is a command-line utility used to query Domain Name System (DNS) servers and retrieve DNS records. It helps administrators verify DNS configurations and identify potential security issues.

In this assessment, the Dig tool revealed that the organization's DNS server **allows DNS Zone Transfer (AXFR)**. A zone transfer is intended to synchronize DNS data between primary and secondary DNS servers. However, if it is enabled for unauthorized users, anyone can download the entire DNS zone database.

The command:

```
dig AXFR example.com @ns1.example.com
```

attempts a DNS Zone Transfer from the DNS server. If successful, the server returns all DNS records instead of denying the request.

The report exposed important DNS information such as:

- Internal hostnames
- Mail servers (MX records)
- IP addresses (A records)
- Name servers (NS records)
- Subdomains
- TXT records
- SOA (Start of Authority) records

This information provides attackers with a detailed map of the organization's network infrastructure.

Security Implications

A successful DNS Zone Transfer exposes sensitive information that should normally remain private.

The exposed internal hostnames reveal server names such as web servers, database servers, backup servers, VPN gateways, development servers, and internal applications. Attackers can use these names to identify valuable targets.

Mail server information allows attackers to discover the organization's email infrastructure. This information can be used to launch phishing campaigns, email spoofing attacks, or spam attacks.

Name Server (NS) records reveal the DNS servers responsible for the domain. Attackers may attempt denial-of-service attacks or exploit vulnerabilities in these servers.

IP addresses allow attackers to identify active systems for further reconnaissance and vulnerability scanning.

SOA records provide administrative information such as the primary DNS server, contact details, serial numbers, and refresh intervals, which help attackers understand the DNS architecture.

TXT records may reveal technologies used by the organization, SPF, DKIM, or verification tokens that assist attackers during reconnaissance.

How Attackers Could Exploit These Findings

An attacker who successfully performs a DNS Zone Transfer can:

- Enumerate all subdomains within the organization.
- Identify internal servers and network architecture.
- Launch targeted attacks against exposed systems.
- Discover mail servers for phishing and email spoofing.
- Perform vulnerability scanning against identified hosts.
- Identify VPN, development, backup, and administrative servers.
- Plan privilege escalation attacks based on discovered infrastructure.
- Gather intelligence for social engineering attacks.
- Use the collected information to increase the effectiveness of penetration testing or real-world attacks.

Since DNS is often the first step in reconnaissance, exposing complete DNS records significantly reduces the effort required for attackers to identify potential targets.

Recommended Best Practices

To secure the DNS infrastructure, the organization should:

1. **Disable unauthorized DNS Zone Transfers** and allow AXFR only between trusted primary and secondary DNS servers.
2. **Restrict Zone Transfers** using Access Control Lists (ACLs) or firewall rules that permit only authorized DNS servers.
3. **Use TSIG (Transaction Signature)** to authenticate DNS zone transfers between DNS servers.
4. **Keep DNS server software updated** to protect against known vulnerabilities.

5. **Implement DNSSEC (Domain Name System Security Extensions)** to ensure the authenticity and integrity of DNS responses.
6. **Configure firewalls** to restrict unnecessary DNS traffic and block unauthorized requests.
7. **Monitor DNS logs** regularly to detect suspicious queries and repeated AXFR attempts.
8. **Remove unnecessary DNS records** that expose internal infrastructure or outdated systems.
9. **Separate internal and external DNS servers** so that internal hostnames are not visible to external users.
10. **Conduct regular DNS security audits** and penetration tests to identify configuration weaknesses before attackers can exploit them.

Conclusion

The Dig assessment revealed that the organization's DNS server permits **DNS Zone Transfer (AXFR)**, exposing sensitive DNS information such as internal hostnames, mail servers, IP addresses, and DNS records. This significantly increases the risk of reconnaissance, phishing, vulnerability scanning, and targeted attacks. Restricting zone transfers, implementing DNSSEC and TSIG, maintaining secure DNS configurations, monitoring DNS activity, and regularly auditing the DNS infrastructure are essential measures to protect the organization from DNS-related security threats.